



TAREA 6: Seguridad básica y respuesta a incidentes



CORE V TECH

EQUIPO CONFORMADO POR:

Ana Raquel Bildoza Duarte

Armando Castellanos Muñoz

Daniela Rubí C. M.

Itzel Anahi Nuñez Escamilla

LIDER:

"Ivan" Armando Santos Flores



Objetivo general

Demostrar que el alumno puede **detectar, contener y documentar** un incidente básico de seguridad, como primer nivel.



Objetivos específicos

1. Reconocer señales de riesgo (phishing, malware, fuga de datos).
2. Aplicar acciones inmediatas de contención.
3. Escalar correctamente si corresponde.
4. Educar al usuario con una recomendación clara.



Instrucciones (Partes)

Parte A. Elige 1 escenario

- Phishing (correo sospechoso)
- Usuario compartió contraseña
- Equipo con posible malware
- Acceso no autorizado / MFA sospechoso

De: Banco de la Nación - Seguridad suporte@actualizacion-banco-alerta.com.rnx

Para: usuario@correo.com

Fecha: 26 de junio de 2026, 11:15 AM

Asunto: URGENTE: Bloqueo preventivo de su cuenta bancaria - Acceso suspendido

Estimado cliente,

Le informamos que hemos detectado un intento de acceso no autorizado a su banca en línea desde una ubicación inusual. Como medida de seguridad, sus productos financieros han sido restringidos temporalmente.

Para reactivar sus servicios y evitar la cancelación definitiva de sus tarjetas, es obligatorio que verifique su identidad y actualice sus credenciales de acceso dentro de las próximas 2 horas.

Por favor, ingrese al siguiente enlace oficial para completar el proceso de desbloqueo de forma segura:

<http://www.actualizacion-banco-alerta.com/banca-linea/identificacion>

Agradecemos su pronta atención a este asunto para mantener la seguridad de sus fondos.

Atentamente,

Departamento de Seguridad y Prevención de Fraudes

Banco de la Nación S.A.

Parte B. Define señales detectadas (mínimo 3)

Ej. remitente raro, enlace extraño, urgencia, adjunto sospechoso, etc.

Para ayudar a detectar las señales que distinguen a un correo sospechoso (Phishing) es importante mantener la calma ante cualquier sentimiento de urgencia que nos haya causado dicho mensaje y ver si podemos detectar algunas de las siguientes señales:

- Remitente con dominio sospechoso y diferente al oficial.
 - [actualizacion](#) la “l” ha sido reemplazada por una i mayúscula (I)
 - [com.rnx](#) el dominio termina con rnx, en lugar de mx
- Enlace no oficial y usando HTTP.
 - **Sugerencia:** Evitar hacer click en cualquier enlace
- Mensaje con urgencia ("2 horas") y amenazas de bloqueo.
- Amenaza de bloqueo/cancelación que indica que las tarjetas serán canceladas si no se actúa, lo cual es típico de correos maliciosos.
- Solicita verificar identidad y actualizar credenciales mediante un enlace.
- Saludo genérico ("Estimado cliente").

Reconocer estas señales es el primer paso para responder de forma segura al incidente.

Parte C. Respuesta L1 (paso a paso)

1. Contención:

- Indicar al usuario que **no haga clic** en el enlace.
- Solicitar que **no ingrese datos personales**.
- Recomendar **cerrar sesión** en banca en línea si la tenía abierta.
- Si hizo clic, pedir que **cambie su contraseña** desde el sitio oficial.
- Si descargó algo, **aislar el equipo** (desconectar de internet).

2. Recolección de info (captura, remitente, hora, enlace)

- Solicitar al usuario el correo original (idealmente exportado en formato .msg o .eml) para revisar las cabeceras (headers):
 - Captura de pantalla del correo.
 - Dirección del remitente.
 - Fecha y hora de recepción.
 - Enlace incluido en el mensaje (sin abrirlo).
 - Confirmar si hizo clic o ingresó datos.
- Extraer los datos como dirección de correo del remitente, dirección IP de origen, y las URLs o enlaces ocultos dentro del mensaje.

3. Escalamiento (a seguridad/sistemas)

- Notificar al equipo de Seguridad de la Información / **Fraude** con toda la evidencia.
- Clasificarlo como **phishing**.
- Notificar al área de TI si se sospecha compromiso del dispositivo.

4. Documentación del incidente

- Registrar el ticket en el sistema detallando el reporte, usuario afectado, acciones tomadas de inmediato (como la contención) y el estado actual del equipo o cuenta.
 - Tipo de incidente: *Phishing por correo electrónico*.
 - Señales detectadas.
 - Acciones de contención realizadas.
 - Información recolectada.
 - Estado del usuario (si ingresó datos o no).
 - Escalamiento realizado.
 - Recomendación final al usuario.

Parte D. Recomendación al usuario (1–2 frases)

"Recuerde que el equipo de TI nunca le solicitará sus credenciales ni datos personales a través de enlaces por correo electrónico. Ante cualquier mensaje que exija acciones urgentes, verifique siempre la identidad del remitente por un canal oficial antes de hacer clic."

"Nunca comparta contraseñas o códigos de verificación por correo electrónico. Ante cualquier duda, reporte el mensaje al área de TI o Seguridad antes de realizar cualquier acción."



REFERENCIAS

1. Imagen de referencia generada con IA